Software Engineering
Lab 5 - Static Code Analysis

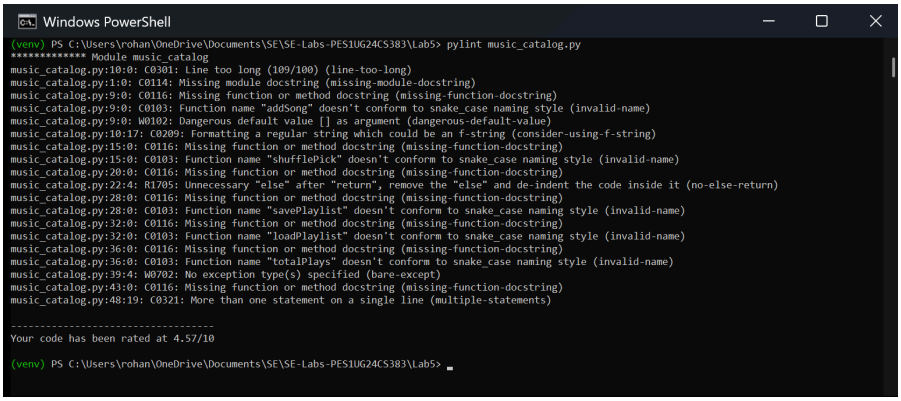
Name : Rohan Suresh
SRN : PES1UG24CS383
Section : G

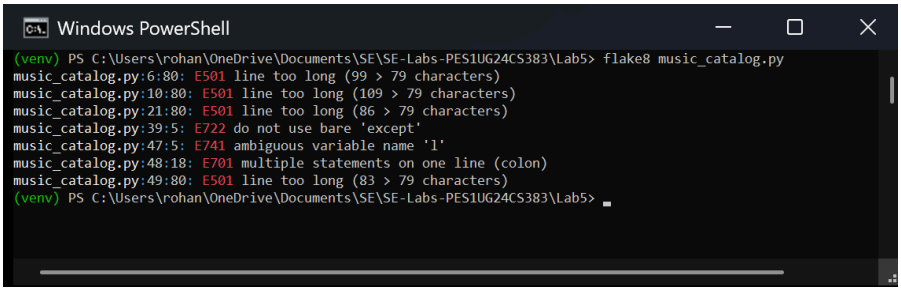
Assigned Repo : https://github.com/SETAPESU26/L5_19_music_catalog
My Repo : https://github.com/RohanMay-Suresh/SE-Labs-PES1UG24CS383 (Lab5 folder)

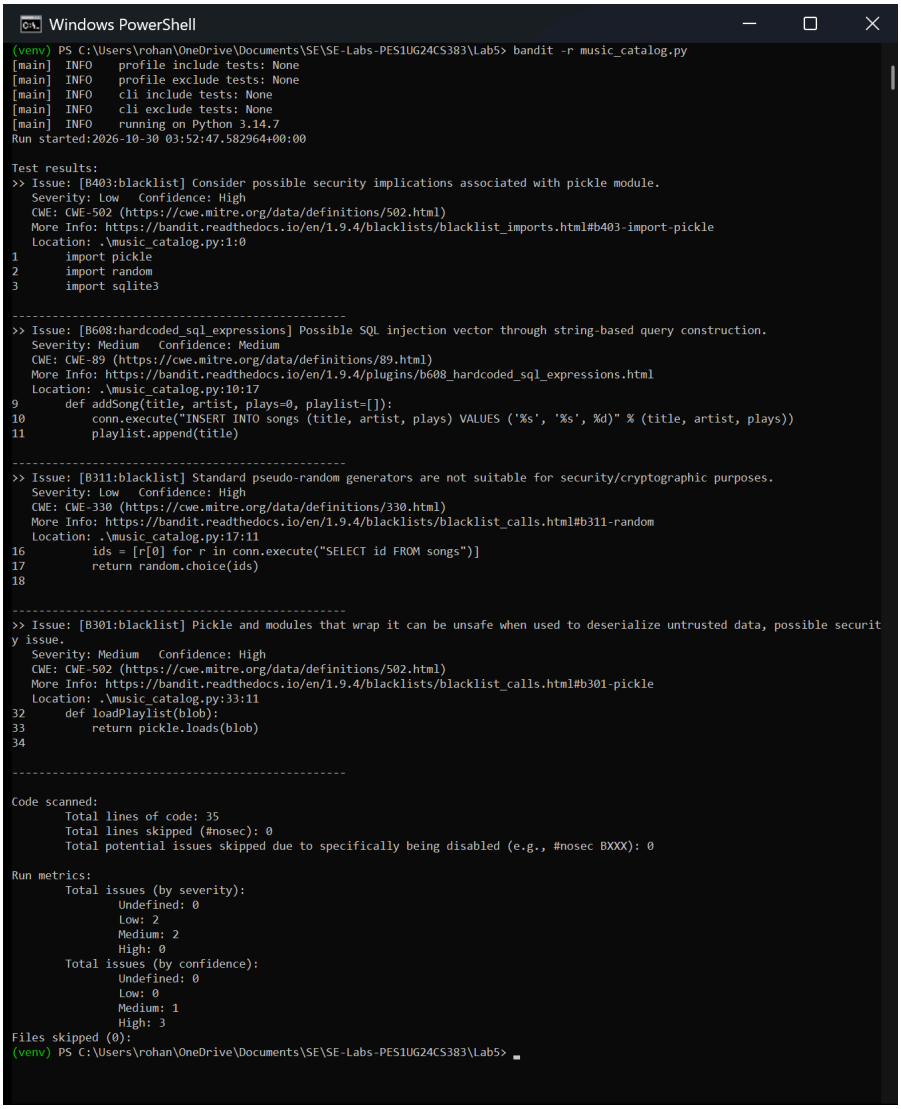
1. Introduction

Static code analysis is checking code for bugs, security problems and style issues without running it. I used three tools on music_catalog.py: **Pylint** (code quality, gives a score out of 10), **Flake8** (PEP 8 style) and **Bandit** (security issues).

2. Issues Found (Before Fixing)







3. Issue Table

Issue	Type	Line(s)	Description	Fix Approach
SQL injection (B608)	Security	10	query built with % formatting, a title like "Don't Stop" crashes it	used ? placeholders
pickle (B301, B403)	Security	1, 33	pickle.loads can run code from untrusted data	used json instead
random.choice (B311)	Security	17	random is not meant for security	used secrets.choice
Mutable default arg (W0102)	Bug	9	playlist=[] is shared between calls	default None, new list inside
Bare except (W0702, E722)	Bug	39	catches every error and hides it	except sqlite3.Error
Naming and docstrings (C0103, C0116)	Style	whole file	camelCase names, no docstrings	snake_case names, added docstrings
Long lines, l variable (E501, E741)	Style	6, 10, 21, 47, 49	lines over 79 chars, unclear name l	split lines, renamed to songs

4. Reports Before and After

pylint_report.txt - before:

```
************* Module music_catalog
music_catalog.py:10:0: C0301: Line too long (109/100) (line-too-long)
music_catalog.py:1:0: C0114: Missing module docstring (missing-module-docstring)
music_catalog.py:9:0: C0116: Missing function or method docstring (missing-function-docstring)
music_catalog.py:9:0: C0103: Function name "addSong" doesn't conform to snake_case naming style (invalid-name)
music_catalog.py:9:0: W0102: Dangerous default value [] as argument (dangerous-default-value)
music_catalog.py:10:17: C0209: Formatting a regular string which could be an f-string (consider-using-f-string)
music_catalog.py:15:0: C0116: Missing function or method docstring (missing-function-docstring)
music_catalog.py:15:0: C0103: Function name "shufflePick" doesn't conform to snake_case naming style (invalid-name)
music_catalog.py:20:0: C0116: Missing function or method docstring (missing-function-docstring)
music_catalog.py:22:4: R1705: Unnecessary "else" after "return", remove the "else" and de-indent the code inside it
(no-else-return)
music_catalog.py:28:0: C0116: Missing function or method docstring (missing-function-docstring)
music_catalog.py:28:0: C0103: Function name "savePlaylist" doesn't conform to snake_case naming style (invalid-nam
e)
music_catalog.py:32:0: C0116: Missing function or method docstring (missing-function-docstring)
music_catalog.py:32:0: C0103: Function name "loadPlaylist" doesn't conform to snake_case naming style (invalid-nam
e)
music_catalog.py:36:0: C0116: Missing function or method docstring (missing-function-docstring)
music_catalog.py:36:0: C0103: Function name "totalPlays" doesn't conform to snake_case naming style (invalid-name)
music_catalog.py:39:4: W0702: No exception type(s) specified (bare-except)
music_catalog.py:43:0: C0116: Missing function or method docstring (missing-function-docstring)
music_catalog.py:48:19: C0321: More than one statement on a single line (multiple-statements)

-----------------------------------
Your code has been rated at 4.57/10
```

after:

```
--------------------------------------------------------------------
Your code has been rated at 10.00/10 (previous run: 10.00/10, +0.00)
```

flake8_report.txt - before:

```
music_catalog.py:6:80: E501 line too long (99 > 79 characters)
music_catalog.py:10:80: E501 line too long (109 > 79 characters)
music_catalog.py:21:80: E501 line too long (86 > 79 characters)
music_catalog.py:39:5: E722 do not use bare 'except'
music_catalog.py:47:5: E741 ambiguous variable name 'l'
music_catalog.py:48:18: E701 multiple statements on one line (colon)
music_catalog.py:49:80: E501 line too long (83 > 79 characters)
```

after: empty file (no issues)

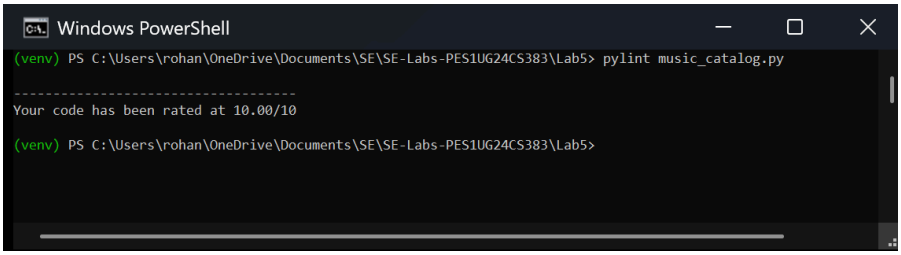
bandit_report.txt (only the issue lines) - before:

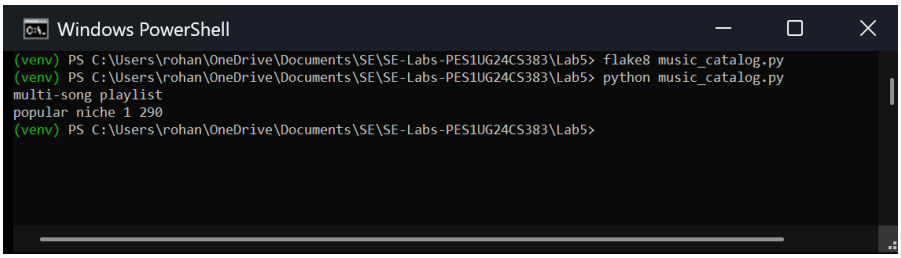
```
>> Issue: [B403:blacklist] Consider possible security implications associated with pickle module.
   Severity: Low   Confidence: High
   Location: .\music_catalog.py:1:0
>> Issue: [B608:hardcoded_sql_expressions] Possible SQL injection vector through string-based query construction.
   Severity: Medium   Confidence: Medium
   Location: .\music_catalog.py:10:17
>> Issue: [B311:blacklist] Standard pseudo-random generators are not suitable for security/cryptographic purposes.
   Severity: Low   Confidence: High
   Location: .\music_catalog.py:17:11
>> Issue: [B301:blacklist] Pickle and modules that wrap it can be unsafe when used to deserialize untrusted data, p
ossible security issue.
   Severity: Medium   Confidence: High
   Location: .\music_catalog.py:33:11
    Total issues (by severity):
        Undefined: 0
        Low: 2
        Medium: 2
        High: 0
```

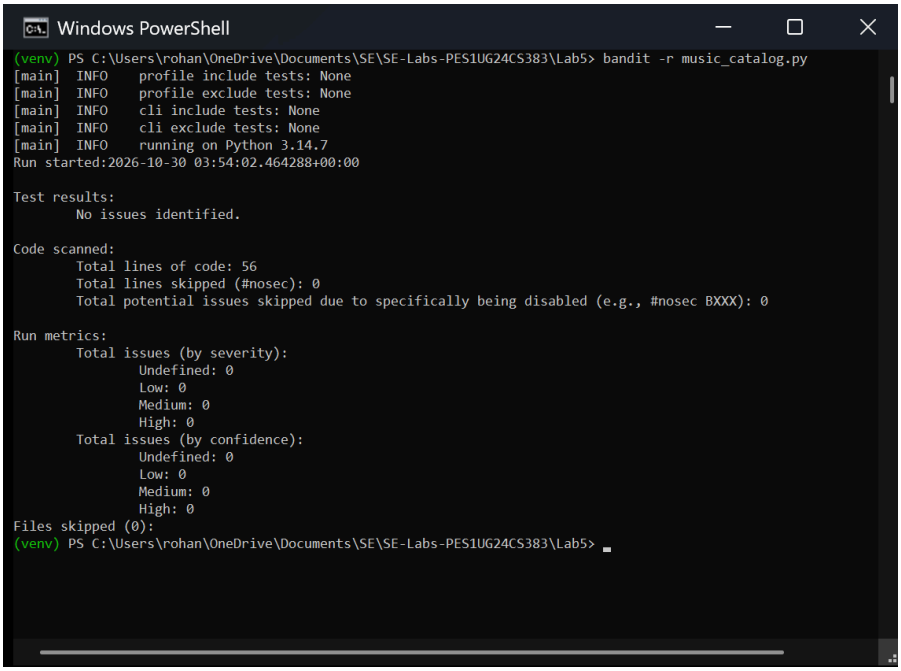
after:

```
    No issues identified.
    Total issues (by severity):
        Undefined: 0
        Low: 0
        Medium: 0
        High: 0
```

5. After Fixing







6. Reflection

1. Which issues were the easiest to fix, and which were the hardest? Why?

Style issues like names, docstrings and long lines were the easiest. Replacing pickle was the hardest since I had to make sure saving and loading the playlist still worked.

2. Did the static analysis tools report any false positives? If so, describe one example.

Yes, Bandit flagged random.choice even though it's just picking a random song, not anything security related.

3. How would you integrate static analysis tools into your actual software development workflow?

Run flake8 and pylint before every commit and add all three tools to CI so they run on every push.

4. What tangible improvements did you observe in the code quality, readability, or potential robustness after applying the fixes?

Titles with apostrophes don't crash the program anymore, the playlist bug is fixed and the code is easier to read. Pylint went from 4.57 to 10.00.